SIMATS ENGINEERING

SIMATS
Saveetha Institute of Medical And Technical Sciences
(Declared as Deemed to be University under Section 3 of UGC Act 1956)

ASSESSMENT TOOL II- ASSIGNMENT

COURSE CODE: ITA14 **COURSE NAME: Ethical Hacking**

COURSE OUTCOME COVERED

CO1: Apply the principle of the foundational concepts of ethical hacking, including types of hackers, ethical principles, legal frameworks, and the role of responsible disclosure in cybersecurity.

ASSIGNMENTS QUESTIONS

1. A company hires you to test its network but gives you only a one-line email authorization with no defined scope. Halfway through testing, you discover a critical vulnerability in a system that wasn't mentioned in the email. Do you exploit it to prove impact? Justify your answer using ethical hacking principles.
2. You are conducting a penetration test and discover that the client's production database contains real customer financial data. Your test plan calls for exploiting a SQL injection vulnerability. How do you proceed without causing harm, and what precautions should have been taken before the engagement began?
3. During a black-box penetration test, you accidentally trigger a denial-of-service condition on a live production server, causing an outage. Walk through what you should have done to prevent this and what your responsibility is now.
4. A client asks you to test their systems but insists you not inform their IT department, wanting to test the team's real-world detection capability. What ethical and practical risks does this create, and how would you structure the engagement to protect yourself?
5. You're asked to perform a "red team" exercise versus a "vulnerability assessment." Using a real-world scenario of a bank wanting to test physical and digital security, explain how your approach, ethics, and rules of engagement would differ between the two.

Code of Conduct:

I 192324021 *(Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment. I understand that any violation of academic integrity rules will result in disciplinary action.*

Rubrics

Criteria	Weightage	Level 4 – Exemplary	Level 3 – Proficient	Level 2 – Developing	Level 1 – Beginning
Understanding of Problem Context	20	Clearly understands the problem and accurately identifies all data-handling requirements and operations	Good understanding with minor gaps	Basic understanding; some requirements unclear	Poor understanding or misinterpretation of the problem
Application of Concepts	30	Accurately applies appropriate data structures and algorithms to solve complex problems	Applies relevant concepts correctly with minor errors	Applies basic concepts with limited accuracy	Fails to apply appropriate concepts
Problem-Solving Approach	20	Logical, well-structured, and efficient approach	Mostly logical approach with minor gaps	Basic approach with some inconsistencies	Illogical or unclear approach
Accuracy of Solution	20	Completely correct code, output and complexity analysis with proper justification	Mostly correct with minor errors	Partially correct solution	Incorrect or incomplete solution

Criteria	Weightage	Level 4 – Exemplary	Level 3 – Proficient	Level 2 – Developing	Level 1 – Beginning
Clarity	10	Clear, well-organized, and properly explained solution	Understandable with minor clarity issues	Limited clarity and explanation	Poorly presented and difficult to understand

ETHICAL HACKING

ITA1405

DATE: 15/10/26 | SLOT - A | NAME: V. Yaswini Reddy

DAY: Thursday | CO1 - AT3 | REG NO: 192324021

1. Discovering a critical vulnerability outside the authorized scope:

Situation:

A company authorizes a penetration test through a one-line email without defining the scope. During testing, I discover a critical vulnerability in a system that was not mentioned in the authorization.

Justification using ethical hacking principles:

→ Authorization and scope:

Ethical hacking must be performed within clearly defined legal boundaries. A general email may establish some permission, but it does not necessarily authorize testing every system belonging to the company.

→ Do no harm:

Exploiting the vulnerability could cause system failure, expose confidential information, or disrupt business operations.

→ Professional responsibility:

I should document the initial discovery using the minimum information necessary, avoid further intrusive testing, and notify the designated client contact securely.

→ Confidentiality:

Any evidence collected must be protected and shared only with authorized individuals.

→ Integrity and Accountability:

I must maintain accurate records of what I discovered, the methods used, and the actions taken.

Appropriate course of action:

1. Stop testing the out of scope system.
2. Record the discovery without performing futher exploitation.
3. Notify the client through the agreed communication channel.
5. Resume testing only after receiving appropriate approval.

2. SQL injection Testing on a production Database Containing Financial Data.

When a production database contains real customer financial data, I would prioritize data protection, service availability, and customer privacy. I would not perform aggressive SQL injection attacks or retrieve real financial records merely to demonstrate the vulnerability.

Instead, I would use a controlled testing approach that provides sufficient evidence of the vulnerability while minimizing the risk of harm.

Steps to proceed safely:

1. Stop and assess the risk:
   Determine whether the planned SQL injection test could expose confidential information, modify records, delete data, or affect database availability.
2. Inform the client:
   Notify the authorized project manager or security contact that the database contains sensitive financial information. Explain the risks and request approval for a safer testing method.
3. Use a test environment:
   Whenever possible, reproduce the vulnerability in a staging environment containing synthetic synthetic or anonymized data instead of real customer records.
4. Use non-destructive testing:
   Use a carefully controlled test input to confirm the vulnerability without extracting sensitive information or modifying database contents. Avoid destructive queries, bulk data extraction, and unnecessary privilege escalation.
5. Protect the evidence:
   Store screenshots, logs and test results securely, restrict access to authorized personnel, and follow the agreed data-retention and decision requirements.

precautions before the engagement began:

The following safeguards should have been established before testing started.

→ Written authorization and a clearly defined scope.
→ Identification of production systems and sensitive data.
→ Rules of engagement specifying permitted and prohibited testing techniques.
→ A documented risk assessment and an agreed testing window.
→ A backup and recovery plan, including restoration procedures where appropriate.

3. Accidental Denial-of-Service on a live production server.

A denial-of-service (DOS) condition occurs when a system becomes unavailable to legitimate users because its resources are overwhelmed or its normal operation is disrupted. During an ethical hacking engagement, an accidental outage can affect business operations, interrupt customer services, and cause financial losses.

An ethical hacker must take preventive measures before testing and respond immediately and responsibly if an incident occurs.

Preventive measures:

→ Define the scope and rules of engagement:
The testing agreement should clearly identify the permitted systems, testing techniques, time windows, and prohibited activities; it should explicitly address whether DOS testing is allowed.

→ Conduct a risk assessment:
Before testing, identify systems that are business-critical and evaluate the possible impact of intensive exploits, automated scans, or resource intensive tests.

→ Obtain specific approval:
DOS testing should not be assumed to be permitted under general penetration-testing authorization. It requires explicit approval and appropriate safeguards.

→ Use a controlled environment:
Whenever possible, perform high-impact testing in a test environment rather than on a live production server.

→ Establish an emergency plan:
Identify the incident-response contact, escalation process, shutdown procedure, and recovery arrangements before testing begins.

Responsibilities after the outage:

→ Stop the test immediately:
Terminate the activity that caused the disruption and avoid repeating the action.

→ Notify the client:
Inform the designated technical contact and incident-response team immediately. Explain the observed symptoms, the testing activity, and the approximate time of the incident.

→ Support Recovery:
Cooperate with the client's authorized IT team to restore normal operations. I would not independently restart services, alter configuration or make other changes unless authorized.

→ Preserve evidence:
Retain relevant logs, time stamps, and test records securely so that the cause and impact can be investigated.

→ Review and improve:
Participate in a post-incident review to identify gaps in testing procedures and recommend improvements to prevent recurrence.

---

4. Testing without informing the IT Department

This situation describes a controlled security exercise designed to evaluate an organization's ability to detect and respond to unexpected activity. Such an exercise can be valuable, but keeping the IT department unaware introduces ethical, operational, and legal risks.

Ethical and practical risks:

→ Incident-response confusion:
The IT team may interpret the testing activity as a genuine cyberattack and initiate emergency procedures

→ Service disruption:
Security monitoring systems may automatically block traffic, disable accounts, isolate servers, or interrupt legitimate services.

gal and authorization risks:

If the approval is vague or comes from someone without sufficient authority, the tester may exceed the permitted scope or act without valid authorization.

→ Impact on business operations:

Unexpected activity may affect customer services, employee productivity, or critical business applications.

→ Risk of escalation:

The IT department might contact external incident-response providers, law enforcement, or other authorities if the activity appears malicious.

How I would structure the engagement:

→ Obtain formal written authorization:

I would obtain approval from an appropriately authorized senior executive or system owner. The authorization must clearly state the purpose, duration, scope, permitted techniques, and limitations

→ Define the rules of engagement:

The agreement should specify the systems and networks that may be tested, testing hours, prohibited actions, data-handling requirements, and conditions requiring an immediate stop.

→ Conduct a debriefing:

After the exercise, disclose the activity to the relevant teams, explain the findings, and assess detection time, response quality, communication, and opportunities for improvement.

5. Red-Team Exercise vs. Vulnerability Assessment in a Bank.

A vulnerability assessment and a red-team exercise are two important cybersecurity techniques used to improve an organization's security. A vulnerability assessment identifies and evaluates security weaknesses, whereas a red-team exercise tests how effectively an organization's security systems can detect and respond to simulated attacks.

→ Vulnerability Assessment:

Objective:

To identify security weaknesses and recommend suitable solutions before attackers can exploit them.

Approach:

1. Identify outdated software, weak passwords, and insecure network configurations.
2. Examine the bank's digital systems and approved physical security controls
3. Evaluate vulnerabilities based on their severity and potential impact.
4. Prepare a report with findings and recommendations for improvement.

Ethical Considerations:

The assessment must protect customer information and avoid disrupting banking operations.

Rules of engagement:

Testing must be limited to authorized systems, and potentially harmful activities must be avoided unless specifically approved.

→ Red - Team Exercise:

Objective:

To evaluate the bank's ability to prevent, detect, and respond to realistic, simulated cyberattacks.

Approach:

1. Simulate authorized phishing attempts to test employee awareness.
2. Test approved physical access controls, such as visitor verification and access cards.
3. Observe how quickly the security team identifies and responds to suspicious activities.

Ethical Considerations:

The exercise must not expose real customer data, access customer funds, or cause unnecessary disruption.

Rules of Engagement:

Written authorization, a clearly defined scope, emergency contacts, and stop conditions must be established before testing begins.